Name: Pranat Agarwal

Batch : 2022 to 2026

A1 :

Risk	Asset	CIA impact	Control	Limitation
1. Using same short password for email and learning portal	Email account and learning-portal account	Confidentiality: due to short password it will be easy to hack that and after it attacker could access both accounts. Integrity: They could change account details and alter work. Availability : can delete learning portal account and when Mira needs it she will not get it or can delete some of her work in that portal.	Use a unique, long , strong password for each account, preferably with a password manager.	A strong password can still be stolen through phishing or malware.
2. Approving unexpected sign-in prompts	Online accounts and personal sensitive information	Confidentiality : An attacker with stolen credentials could gain access in Mira's account . Integirity: can alter any information it want. Availability: Can do any thing in her account like changing password and when she needs to login she will not able to do that.	Reject unexpected MFA prompts and verify the login before approving it.	This relies on Mira recognising suspicious prompts and not accidentally approving one.
3.Postponing device updates	Operating System and Stored files	Confidentiality, Integrity & Availability: Unpatched vulnerabilities , old security settings , old firewalls and weak and unpatched system defenders can be exploited to install malware, steal information or disrupt the device.	Enable automatic security updates and install updates timely.	Updates may require restarts and can occasionally cause compatibility problems.
4. Keeping only project copy in one laptop	Project files	Confidentiality , integrity and Availability: Laptop failure, theft, accidental deletion or ransomware could make the project permanently unavailable. Attacker if got system access then can change project scope or can add maliscus code in it.	Maintain regular backups, such as an external backup and/or trusted cloud storage.	Backups must be performed regularly and can themselves be compromised if not protected.
5. Friend using the laptop under Mira is signed in account	Mira's accounts, files and account personal information	Confidentiality & Integrity availability: The friend could view private information or modify/delete files and access the learning portal using Mira's active session.	Logout from the laptop account when unattended and create a separate user account for the friend.	Mira must remember to lock the device; a separate account does not protect against all malware or physical attacks.

A2: Priorities

1. Reject unexpected sign-in prompts first. This is the most immediate risk because an attacker may already possess Mira's password and could gain access simply by getting her to approve a fraudulent request.

2. Install security updates. Keeping the laptop unpatched leaves known vulnerabilities available to attackers and can put both accounts and project files at risk.

3. Use a separate account for the friend. Mira should lock her laptop when not using it and ensure that friends do not use her signed-in account. This reduces the risk of unauthorised access to her accounts and files.

A3: Authentication vs Authorisation

Authentication is the process of proving who the user is. For example, Mira enters her learning-portal username and password and completes MFA to prove that she is Mira.

Authorisation determines what an authenticated user is allowed to do. Once Mira is authenticated, the portal may authorise her to view her courses, upload assignments and see her grades, while preventing her from changing another student's grades.

Therefore, authentication answers “Who are you?” while authorisation answers “What are you allowed to do?”

B1: Warning signs

Warning sign — relevant phrase	Why it needs scrutiny
“FINAL WARNING”	Creates urgency and fear, encouraging the student to act before thinking or verifying the message.
“expires in 20 minutes”	An unusually short deadline is a common pressure tactic used to prevent independent verification.
“enter your college password and OTP”	Asking for both a password and one-time password is highly sensitive and should not be done through an unexpected message or link.
“Do not contact the college office”	Discouraging independent verification is suspicious because a legitimate scholarship communication should not normally prevent students from contacting official staff.
“Reply with a photo of your identity card”	Requests for identity documents through an unexpected email create a significant privacy and identity-theft risk.

B2: **Safe verification process**

1. **Do not click the link, reply, or provide the password, OTP, or identity card.**
2. Independently open the college's **known official portal** by typing its address manually or using a previously trusted bookmark.
3. Check whether the scholarship approval or warning appears in the official student portal.
4. Alternatively, obtain the college's official contact details independently—for example, from the college website, student handbook, or a known official office—and contact the scholarship/financial-aid office directly.

5. Provide the suspicious message to the official office for verification without forwarding sensitive credentials.

HTTPS alone does not prove legitimacy. HTTPS encrypts the connection but does not establish that the website belongs to the college. Similarly, a familiar-looking **display name** can be easily chosen by an attacker; the actual sender address and independently verified domain matter.

B3: Response plan if the student already entered a password and OTP

1. **Immediately stop interacting with the message** and do not provide any additional information.
2. Using the **official college portal or another trusted device**, change the compromised college password immediately. If the same password was used elsewhere, change it there too.
3. Contact the college's official IT/security or account-support team using independently obtained contact details and report that the password and OTP were entered into a suspicious site.
4. Ask the official team to check for **unauthorised logins, account changes, forwarding rules, or other suspicious activity**.
5. Review recent account activity and security settings through the official portal and remove anything unfamiliar.
6. Continue monitoring the account and follow any additional instructions from the college's security team.

The student should **never send the password or OTP to anyone**, including someone claiming to investigate the incident.

B4: What cannot be established

The message alone cannot establish **whether the sender or website is genuinely operated by the college**. Additional evidence such as the college's official records, independently verified domain ownership, email authentication results, or confirmation from the college scholarship office would be needed.

C1:

Time	Observed event	Interpretation
09:00–09:01	student07 from **192.0.2.10** had a successful password authentication and MFA success.	This is consistent with a legitimate sign-in, especially because the lab notes identify this as the usual classroom egress.
10:14	student07 from **198.51.100.23** had a **successful password authentication**.	This is an unusual source compared with the normal classroom IP, but the IP alone does **not** identify an attacker.
10:15–10:16	From 198.51.100.23, two password attempts failed.	This could indicate repeated login attempts or incorrect credentials, but the logs alone cannot establish who made them.
10:17–10:20	MFA success was recorded at 10:17, MFA was denied at 10:18, and a session was created at 10:20. The student says they approved a prompt at about **10:18** to stop repeated requests and denies signing in after 09:05.	The successful MFA and later session creation may indicate that a sign-in was ultimately approved, but the exact relationship between the 10:17 success, 10:18 denial/approval statement, and 10:20 session requires further investigation.

C2: **Explanation and additional checks**

Likely explanation: Someone may have obtained the student's password and attempted to access the account. The repeated attempts generated MFA prompts, and the student's approval may have allowed the session to be created.

Alternative explanation: The activity could have been caused by a legitimate but unusual login, such as a different device, browser, network or authentication process that the student does not recognise.

The IP address **does not identify the person** who made the login attempts.

Two additional checks:

1. Check authentication logs for the **device, browser, MFA method and session ID**.
2. Review **active sessions, login history and security events** for unfamiliar devices or account changes.

C3: Three prioritised response actions

1. **Protect the account:** Reset the password, revoke active sessions/tokens and review or re-register MFA if required.
2. **Preserve evidence:** Secure authentication, MFA, session and relevant endpoint/network logs before they are deleted or overwritten.
3. **Investigate:** Compare device/browser/session information with the student's known activity and escalate the incident according to the college's security procedure.

C4: Incident summary

On 18 October, student07 successfully logged in from the usual classroom IP at 09:00–09:01. At 10:14, a successful password authentication occurred from a different IP, followed by failed password attempts and several MFA events. The student states they did not sign in after 09:05 but approved an MFA prompt around 10:18 to stop repeated requests. This suggests possible account compromise, but the evidence does not prove who caused the activity. IT should first protect the account, preserve all relevant logs and investigate device, session and authentication details.

D1: **Five unsafe or unsupported claims/actions**

AI output	Correction	Why
"The email is safe because it uses HTTPS."	HTTPS **does not prove that an email or website is legitimate**.	HTTPS protects the connection between the browser and website, but a fraudulent website can also use HTTPS.
"The sign-in logs prove that the person using 198.51.100.23 stole the password."	The logs show authentication activity from that IP, but **do not prove who used it or how the password was obtained**.	The scenario explicitly says a different IP alone is not proof of an attacker. Additional device, session and authentication evidence is needed.
"MFA prevents every account compromise."	MFA **reduces the risk but does not prevent every compromise**.	In the scenario, the student says they approved an unexpected MFA prompt, potentially allowing an unauthorised login.
"Delete the suspicious logs."	**Preserve the logs as evidence** and restrict access to them.	Deleting logs can destroy evidence needed to determine what

		happened and investigate the incident.
“Send the student's password to support so they can test it.”	**Never send or disclose the password or OTP.** Reset the password through the official process instead.	Passwords and OTPs are authentication secrets. Support staff should not need the student's secret credentials to investigate an incident.

D2: Better AI-analysis prompt

Analyse only the synthetic evidence provided in this question. Identify the observed facts from the logs and user statement, and clearly separate them from interpretations, assumptions and possible explanations. Do not claim that an IP address identifies a person or that an event proves an attack unless the evidence establishes it. Identify uncertainty and explain what additional evidence would help distinguish competing explanations. Do not request, reproduce, or expose any passwords, OTPs, tokens, personal identifiers or other secrets. Recommend only safe incident-response actions such as account protection, evidence preservation and official investigation. Do not invent facts that are not present in the supplied synthetic evidence.

D3: Corrected security advice (100–150 words)

The available evidence indicates unusual account activity, but it does not prove who caused it or how the password was obtained. The successful authentication from a different IP is noteworthy, but an IP address alone cannot identify an attacker. The repeated password and MFA events, together with the student's statement about approving a prompt, create a credible possibility of account compromise.

The authorised IT team should first protect the account by resetting the password, revoking active sessions and reviewing MFA settings. They should preserve authentication, MFA and session logs before they are overwritten. IT should then compare device, browser and session information with the student's known activity. The student should never disclose their password or OTP to support staff. HTTPS does not by itself establish that a website or message is genuine.

D4: AI-use declaration and evidence notes

AI-use declaration: AI was used to help organise and draft the security analysis. The final reasoning was checked against the synthetic evidence supplied in the question.

Evidence/reference notes:

1. **Scenario evidence:** The question states that a different IP alone is not proof of an attacker and that the student approved an MFA prompt around 10:18.
2. **Security principle:** CISA guidance recommends treating unexpected MFA requests cautiously because attackers can use repeated MFA prompts to trick users into approving fraudulent authentication.